

Malware Concepts: Trojan

This opens a new series on core malware concepts, sitting at a different layer than your offensive tooling guides (Hydra, Kerberoasting, SUID) — those covered how an attacker *gets in and escalates*; this series covers the *payloads* that get delivered once they're in, or that serve as the delivery mechanism itself. A Trojan is the right place to start, since it's less a specific technical mechanism and more a **category defined entirely by deception** — worth locking that distinction in before comparing it against the Virus and Worm guides that follow, since all three get conflated constantly in casual usage despite being fundamentally different in how they spread.

1. What a Trojan Actually Is — The Foundation

A Trojan (Trojan Horse) is malware disguised as, or bundled within, something the victim believes is legitimate and wants to run — named directly after the Greek mythology stratagem, and for good reason: the entire mechanism depends on the victim voluntarily executing it themselves.

The single defining trait that separates a Trojan from every other category in this guide: a Trojan does **NOT self-replicate** and does **NOT self-propagate**. It relies entirely on **SOCIAL ENGINEERING and deception** to get executed in the first place — no self-spreading mechanism, no exploitation of a vulnerability required to gain that initial execution.

Common Disguises / Delivery Vectors

- A cracked/pirated version of legitimate paid software
 - A fake software update or codec/driver installer
 - An email attachment disguised as an invoice, resume, or document
 - A trojanized mobile app on an unofficial app store
 - A "free" game, utility, or browser extension
-

2. How a Trojan Actually Operates Once Executed

1. **DECEPTION** → the victim is convinced the file/program is legitimate and desirable, through social engineering, a convincing fake interface, or

bundling with genuinely functional software.

2. **EXECUTION** → the victim runs it themselves, granting it whatever privilege level their own user session has.
3. **PAYLOAD** → the actual malicious functionality activates, often while the disguise (a working game, a functional utility) continues operating normally in the foreground, to delay suspicion.

Why the "Working Disguise" Detail Matters

Many Trojans deliberately include genuinely functional legitimate software alongside the malicious payload specifically so the victim has no immediate reason for suspicion — the fake video converter actually converts video, while quietly installing a backdoor in the background.

3. Categories of Trojan by Payload Function

A Trojan is fundamentally a **delivery mechanism** — the disguise and social engineering method stay consistent across variants, but what the payload actually does varies widely, and often overlaps directly with other categories in this series:

Trojan Category	Payload Function
Backdoor Trojan	Opens persistent remote access for an attacker (heavy overlap with the RAT guide — many RATs ARE delivered as Trojans)
Downloader Trojan	Doesn't carry the full malicious payload itself; instead downloads and installs additional malware after execution
Banking Trojan	Specifically targets financial credentials and online banking sessions, often through browser injection or form-grabbing techniques
Ransomware Trojan	Delivers encryption-based extortion malware disguised as legitimate software
Rootkit-delivering Trojan	The initial execution vector for a rootkit's installation (see the Rootkit guide for what happens next)

This overlap is worth sitting with rather than glossing over: "Trojan" describes the *delivery/deception method*, while "RAT," "Ransomware," and "Rootkit" describe *what the payload does once installed* — a single piece of malware is

very often accurately described by both a delivery-method term and a payload-function term at the same time.

4. Why Trojans Remain So Effective

- They exploit **HUMAN trust and judgment** rather than a technical vulnerability, which means patching software does nothing to stop them — the "vulnerability" is a person's willingness to run something that looks legitimate.
- They frequently arrive through channels that already carry an implicit trust signal — a colleague's email, a familiar-looking download page, an app store listing with real (if fabricated or stolen) reviews.
- Modern Trojans are frequently digitally signed with stolen or fraudulently obtained certificates, defeating a signature-based trust check a more cautious user might otherwise rely on.

5. Real-World Impact

Impact	Description
Initial access foothold for broader compromise	Trojans are one of the most common INITIAL access vectors in real-world breaches, frequently serving as the first stage before a downloader variant pulls in further tooling.
Credential and financial theft	Banking Trojans specifically remain a major source of direct financial fraud losses globally.
Supply-chain-adjacent risk	Trojanized versions of legitimate software distributed through compromised or unofficial download sources represent a persistent and hard-to-fully-close risk vector.

6. Detection Considerations

- **Behavioral analysis** (sandboxing, EDR runtime monitoring) is generally far more effective against Trojans than static signature matching, given how easily disguises and packing can be varied between samples.
- Unexpected outbound network connections shortly after a new program's first execution are a strong indicator, particularly for backdoor and downloader variants.

- Digital signature verification, while a good practice, is not a complete defense given the prevalence of stolen/fraudulent signing certificates noted in Section 4.
 - User-reported "this doesn't look right" observations remain a genuinely valuable detection source, since the disguise itself is sometimes imperfect enough for an attentive user to notice.
-

7. Prevention

- User awareness training focused specifically on the deception mechanism (unexpected attachments, too-good-to-be-true free software, unofficial download sources) addresses the actual root cause more directly than most technical controls alone.
 - Application allowlisting, restricting execution to a known-good set of approved software, directly defeats the "victim runs it themselves" mechanism this entire category depends on.
 - Maintain and enforce use of official, verified software distribution channels (official app stores, vendor websites) rather than third-party download aggregators.
 - Deploy endpoint detection with behavioral analysis capability rather than relying solely on static signature-based antivirus.
 - Apply least-privilege principles to standard user accounts, so that even a successfully executed Trojan is constrained in what it can actually do without further privilege escalation.
-

Quick Reference Cheat Sheet

Defining Trait

Requires victim to voluntarily execute it — no self-replication, no self-propagation, entirely dependent on deception.

Common Disguises

- Pirated/cracked software
- Fake updates

- Malicious attachments
- Trojanized mobile apps
- "Free" utilities

Payload Categories — What It Delivers Once Run

Trojan Category	Payload
Backdoor Trojan	Persistent remote access
Downloader Trojan	Fetches further malware
Banking Trojan	Targets financial credentials
Ransomware Trojan	Delivery vector for encryption extortion
Rootkit-delivering Trojan	Installs a rootkit

Key Distinction From Virus / Worm

Malware Type	Defining Behavior
Trojan	Does NOT self-replicate or self-spread
Virus	Self-replicates but needs a host file/user action to spread
Worm	Self-replicates AND self-spreads autonomously across a network